

GSPro

Аудит готовности

Границы подтверждений, замечания и условия приёмки

Редакция 26 сентября 2026 · Revision 3

Источник: docs/AUDIT.md

Редактируемый Markdown является источником текста. Статусы проверки и эксплуатационные ограничения приведены в самом документе; эта редакция не заменяет фактический контроль работающего сервера.

Команды копируйте из исходного Markdown: в PDF длинные строки визуально перенесены для печати.

Оглавление

1. Вывод	3
2. Объём и достоверность проверки	3
3. Что подтверждено и исправлено	4
4. Блокеры открытия продаж - P0	5
5. Существенные технические замечания - P1	5
6. Дополнительные замечания - P2	6
7. Платёжные случаи для приёмки	6
8. Устанавливаемое веб-приложение (PWA)	6
9. Условия передачи и следующего запуска	7

Prod-1.1 | Код переносимого комплекта на 26 сентября 2026 | Техническая передача заказчику

1. Вывод

Код сайта, Mini App и бота подготовлен к передаче вместе с контейнерной установкой. Это не означает готовность к приёму реальных платежей. Открытие продаж требует закрытия платёжных и организационных блокировок, исправления существенных технических замечаний и сквозной приёмки.

Рабочий сайт технически доступен. Действующий режим запрещает реальную оплату. Для нового VPS подготовлен отдельный установщик; начальный режим также без реальных платежей. Старое имя режима stage5 в коде не является второй производственной сборкой: имя выпуска - Prod-1.1.

2. Объём и достоверность проверки

Основа исходного аудита от 24.09.2026: исходники текущего VPS, конфигурация контейнеров, миграции, агрегаты БД, HTTP-проверки и выборочный осмотр интерфейса. Проверка охватывала главную, товар, юридическую страницу, вход, Mini App, гостевые обращения к API и мобильную главную. Текущий переносимый код содержит последующие изменения регистрации, аккаунта, прав, почты и платёжного выключателя. Датированные результаты прежнего прогона не служат подтверждением новой сборки; повторная приёмка нужна отдельно.

Для прежней версии пакета была выполнена контейнерная проверка установщика: сборка приложений, пустая PostgreSQL, создание владельца, вход, ограниченная роль БД, восстановление дампа и SQLite-состояния бота. Её результаты приведены в VERIFICATION.md с датой прогона. Для обновлённого переносимого кода 26.09.2026 прошли 34 Python/Bash теста установщика и 4 мокированных теста резервных писем; это не заменяет сборку и сквозную установку нового Ubuntu VPS. После добавления новых миграций и функций контейнерную проверку следует повторить на итоговом релизном составе.

Не засчитываются как выполненные: создание отдельного нового VPS от начала до конца; реальная оплата/возврат/чек; проверка доставки писем в почтовые ящики; полная матрица прав в живом Telegram; длительная нагрузка; юридическая экспертиза документов и договоров. Аудит не является независимым пентестом.

3. Что подтверждено и исправлено

Область	Статус и основание
Действующий сайт	Web, Mini App, bot и PostgreSQL healthy; Caddy обслуживает HTTPS.
Релиз	Актуальные исходники Prod-1.1 включены в единый репозиторий; добавлен переносимый установщик.
База	Runtime-поль без superuser/createdb/createrole; PostgreSQL не публикуется наружу.
HTTPS	На текущем VPS включено автоматическое управление сертификатами Caddy. На новом VPS требуется работающий DNS и доступные порты.
Передача конфигурации	Секреты исключены из Git; новый установщик генерирует их, при восстановлении сохраняет оригинальные ключи шифрования.
Установка	В коде применяются миграции; существующие тома/непустая база защищены от перезаписи; владелец создаётся только в новой базе. После миграций и до публичного запуска checkoutEnabled устанавливается в false.
Продажи	Отдельная команда с preflight. Старый PLATEGA_ENABLED больше не единственный выключатель: новое поле БД имеет приоритет. Установщик выключает его при свежей установке/восстановлении и включает только после успешного запуска режима продаж.
Диск текущего VPS	Ранее выполнена очистка подтверждённых старых копий и образов. Временные материалы новой проверки удаляются после неё.
Резервные копии текущего VPS	Настроено отдельное S3-хранение; проверены архив и восстановление БД. Новому VPS эта настройка не наследуется автоматически.
Состояние бота	Новый установщик принимает согласованный state.sqlite и проверяет его целостность перед импортом.

В новом пакете добавлены автоматические проверки GitHub Actions. Наличие workflow не равно успешному первому запуску; результат конкретного коммита проверяется на вкладке Actions. Исторические отчёты Stage5-Stage8 не подменяют свежую приёмку Prod-1.1.

4. Блокеры открытия продаж - P0

Наблюдение	Что нужно выполнить / кто отвечает
Реальные платежи выключены; производственные настройки не подтверждены	Владелец предоставляет действующий Platega merchant/secret. Разработчик проверяет callback, суммы, повторы, отмену и сверку.
Продавец и юридические документы не утверждены	Владелец заполняет реквизиты, утверждает документы, контакты, сроки исполнения и возврата.
Фискализация не подтверждена	Владелец и его профильный специалист обеспечивают рабочую схему чеков. Программной интеграции кассы в проверенном коде не обнаружено. Флаг в .env её не создаёт.
Нет подтверждённой сквозной приёмки оплаты, исполнения и возврата	На согласованном заказе проверить деньги, заказ, исполнителя, чек, письмо и возврат; сохранить доказательства.

Статус REFUNDED в админке не отправляет команду возврата денег в Platega. Нельзя обещать автоматический возврат покупателю на основании смены статуса. До продаж нужен утверждённый ручной процесс либо отдельная реализованная интеграция.

Четыре флага production preflight относятся к фактически выполненным действиям: DATA_RESIDENCY_CONFIRMED, LEGAL_TEXTS_APPROVED, PAYMENT_FISCALIZATION_CONFIGURED, PROCESSOR_AGREEMENTS_CONFIRMED. Юридическая применимость и состав необходимых документов определяются владельцем с профильным специалистом; технический аудит этого не подтверждает.

5. Существенные технические замечания - P1

Код	Наблюдение и критерий закрытия
SEC-03	Загрузка медиа разбирает formData до окончательной проверки размера. Ограничить тело до разбора и проверить крупную загрузку на стенде.
PAY-01	Административные статусы оплаты/возврата могут расходиться с фактическим движением денег. Ограничить переходы, связать их с фактами провайдера и проверить роли.
MAIL-01	Бизнес-письма не имеют надёжной очереди повторной доставки. Добавить outbox/retry и наблюдение за недоставленными письмами.
DEP-01	Снимок advisory от 24.09.2026 требует повторной проверки для итоговых lock-файлов, обновления подходящих версий, пересборки обоих приложений и тестов.

В текущем коде обязательная 2FA проверяется перед доступом сотрудника, readJson ограничивает фактически прочитанные байты, лимиты запросов вынесены в PostgreSQL, а удаление аккаунта имеет 72-часовой срок и процедуру обезличивания с защитой незавершённых платежей. Эти изменения требуют проверки на итоговой сборке и не задним числом исправляют результаты старой эксплуатации.

DEP-01: проверка npm registry от 24.09.2026 выявила восемь записей: шесть high и две moderate, пакеты deepmerge-ts 7.1.5, effect 3.16.12, postcss 8.4.31 и sharp 0.34.5. Это **исторический снимок**, а не актуальное заключение по новой сборке и не доказательство эксплуатируемости каждого пути. Для sharp важны платформа и бинарники; production использует Alpine.

Примеры первичных записей advisory: <https://github.com/advisories/GHSA-ggr8-5vv4-36mx> ;
<https://github.com/advisories/GHSA-38f7-945m-qr2g> ; <https://github.com/advisories/GHSA-fxqj-rqcc-2cmp> ;
<https://github.com/advisories/GHSA-f88m-g3jw-g9cj> . Полный машинный снимок включён в docs/evidence.

6. Дополнительные замечания - P2

Регистрация в новом коде требует подтверждения email; нужна сквозная проверка доставляемости, сроков и отказов на итоговом сервере. Публичное имя автора отзыва может формироваться из части email; требуется согласованное отображаемое имя/маска. Нужно проверить соответствие SEO фактическому ассортименту и исключение административных страниц из индексации.

Сроки хранения обращений, аудита и заказов нужно связать с конкретными задачами очистки. Новый установщик намеренно не включает автоматическое окончательное удаление аккаунтов: после 72 часов их завершает уполномоченный сотрудник с паролем и 2FA. Таймер удаления завершённых игровых паролей решает отдельную, более узкую задачу.

Базовые образы Node, PostgreSQL и Caddy пока заданы обновляемыми тегами без digest. Lock-файлы закрепляют пртм-пакеты, но не всю операционную среду. Для строгой воспроизводимости нужны digest, реестр образов и управляемый процесс обновления. Web и Mini App дублируют бизнес-библиотеки; исправления надо переносить в оба приложения.

Необходимо отдельно проверить доступность интерфейса, клавиатуру, фокус и закрытие модальных окон, контраст, ширины 320-1440 px, iOS Safari, Android Chrome и реальный Telegram. Целевые метрики скорости и устойчивости должны быть согласованы и измерены, а не объявлены достигнутыми.

7. Платёжные случаи для приёмки

1. Успешная оплата: точная сумма и валюта, один оплаченный заказ, корректное исполнение и чек.
2. Два одинаковых callback и параллельные события не создают двойное исполнение.
3. Отклонённая/истёкшая оплата понятна покупателю и поддержке.
4. Неопределённая попытка без transactionId не провоцирует повторное списание. UUID сверяется с кабинетом, затем используется ручная сверка.
5. Возврат подтверждён провайдером, а не только административным статусом.
6. Поздний chargeback и пропущенный callback выявляются отдельной операционной сверкой; текущая фоновая задача не опрашивает бесконечно все завершённые транзакции.
7. Оператор чата не может подменить оплату, возврат, цену или доступ другого сотрудника.

8. Устанавливаемое веб-приложение (PWA)

На действующем сайте проверен /manifest.webmanifest: имя GSPro Store, начальная страница /, режим standalone, иконка и цвета. Пользователь сообщил об успешной установке на Android; отдельный сквозной прогон установленного приложения аудитором не выполнялся.

Ссылка для установки - <https://gspro.store/>. Установка выполняется браузером с подтверждением пользователя. Это веб-версия магазина, а не отдельная Android-разработка или публикация Google Play. Офлайн-работа и push-уведомления отсутствуют в текущей реализации.

На iPhone предусмотрен стандартный способ добавления сайта через Safari на экран «Домой». Он описан в инструкции деплоя; собственная iOS-сборка не создавалась. Установка и полный сценарий GSPro на реальном iPhone пока не проверены.

В мобильную приёмку добавить запуск через иконку, вход/выход, сохранение сессии, каталог, переход к платёжному провайдеру и возврат к заказу. Поведение на разных браузерах, версиях Android и iOS пока не подтверждено.

9. Условия передачи и следующего запуска

Техническая передача включает код, установщик, README, карту проекта, инструкцию деплоя, аудит и результаты тестов. Доступы и рабочая база передаются отдельно защищённым способом. Для нового VPS отдельно назначаются ответственные за резервные копии, мониторинг, обновления и реагирование на недоступность.

Продажи открываются после закрытия P0, существенных P1 и сквозной приёмки. Для каждого открытого пункта назначаются ответственный, срок и проверяемый результат. Исключения фиксируются явно владельцем; установка галочек и успешный healthcheck не являются заменой приёмки.